Analyser les usages de l’intelligence artificielle et leurs risques pour le système d’information

Shadow IA chez Hexalp

Preuve de travail destinée au formateur • Olivier HIMBLOT • 20 octobre 2026

Critère évalué

Les usages de l’IA sont recensés avec leurs comptes, leurs données et leurs accès, rattachés à la PSSI et qualifiés, avec des actions prioritaires qui répondent au besoin métier.

Pièces de travail présentées

Inventaire et analyse des usages IA ; cinq actions prioritaires ; note de synthèse au RSSI ; réponse au manager.

Portée de la preuve

Analyse documentaire d’un cas fictif, à partir des dix pièces du dossier Hexalp, dont les cinq tableaux fournis en captures. Dix fiches couvrent neuf familles d’outils. L’état d’activation de HelpFlow et l’usage effectif d’Ollama restent à vérifier. Les secrets sont caviardés.

Ce document prouve un travail d’analyse et de proposition. Il ne prouve ni intervention sur un SI réel, ni déploiement des mesures, ni acceptation des risques, ni envoi des messages proposés.

Lecture du dossier

Page 2 : synthèse du critère et des preuves. Pages suivantes : dix fiches en sept étapes, actions prioritaires, note RSSI, réponse au manager et limites de preuve. Les références internes sont celles de la PSSI fictive v3.2 de mars 2022.

Correspondance avec le critère d'évaluation

Attendu	Travail et preuves disponibles
Recenser les usages et les comptes	Dix fiches U1–U10 ; rapprochement proxy, dépenses, consentements, parc, échanges et note de version. Comptes et offres inconnus explicitement signalés.
Identifier données et accès	Classes C2/C3, secrets caviardés, périmètres IDE, extension et permissions OAuth ; contenu effectif séparé du contenu seulement accessible.
Rattacher à la PSSI	Articles 2.1, 2.3, 4.1, 4.4, 5.2, 5.5, 7.1 et 8.1 selon chaque cas ; écart établi distingué de l'absence de preuve.
Qualifier les risques	Événement redouté, gravité, vraisemblance et score. Échelle pédagogique : 1–3 faible, 4–6 modéré, 8–9 élevé, 12–16 critique.
Choisir des actions métier	Cinq actions ordonnées, responsables et échéances ; supervision, support, recrutement et travail commercial maintenus par des alternatives.
Communiquer aux parties prenantes	Note courte à Nadia et réponse factuelle à Marc en neuf lignes, non envoyées.

Résultats établis dans le scénario

Les pièces décrivent l'envoi de configuration et logs WMS par Julien, le script API de Sofia, l'import de 340 candidatures, des accès ChatGPT commerciaux, un achat et trois consentements MeetNote, une extension sur 14 postes, Copilot sur deux postes, Ollama installé et des accès DeepL. La note HelpFlow annonce une fonction IA activée par défaut : le déploiement et le traitement effectifs restent à confirmer.

Limites à conserver pour l'évaluation

Les requêtes et octets ne sont ni des prompts ni des preuves de contenu sensible. Un consentement prouve des droits, pas toutes les actions possibles. Une installation ne prouve pas un usage. Le sondage anonyme de juin ne permet pas d'identifier les salariés ou de mesurer septembre. Les risques résiduels ne sont pas vérifiés.

U1 — Sofia : résumer les alertes Zabbix et proposer une action

Source : P6. Besoin métier : rendre l'astreinte plus lisible, sans perdre les alertes exploitables. **Statut : usage déclaré par Sofia et trafic API corroboré par P2**, validation DSI inconnue ; ne pas confondre ce message avec une autorisation ou la preuve d'un usage inconnu de toute l'organisation.

Étape	Analyse
1. Outil et fournisseur	Script sur SRV-SUPERV-02, chemin /opt/scripts/zbx_resume.sh, API OpenAI chat/completions, destination Teams. Le fournisseur API est identifié ; modèle, projet, région et réglages inconnus. Le cron est configuré toutes les cinq minutes ; P2 montre 1 440 requêtes vers API OpenAI, 52 Mo envoyés et 9 Mo reçus sur la période ; le succès de chaque résumé reste inconnu
2. Compte	Clé créée sur le compte personnel de Sofia selon son message ; environ 5 €/mois déclarés. Identité système svc-zabbix, compte de base zbx_ro et webhook Teams ; propriétaires, droits effectifs et facturation à vérifier
3. Données	Requête SQL sur les champs **host, ip, name** des alertes actives : noms de machines, adresses et intitulés d'alertes, **C2** proposés pour la cartographie et les incidents. Volume et éventuels contenus personnels dans les intitulés inconnus. Mot de passe SQL **[CAVIARDÉ]** et clé API **[CAVIARDÉE]** écrits dans le script : **C3**. La clé sert à l'authentification API ; le mot de passe SQL n'est pas montré comme envoyé dans le prompt
4. Accès et connecteurs	Lecture SQL prévue ; le nom zbx_ro ne prouve pas les restrictions réelles. Appels réseau automatisés et écriture dans un canal Teams via webhook. L'IA propose une action en texte ; **aucune exécution de cette proposition sur le SI n'apparaît dans le script**. Un champ d'alerte contrôlable par un tiers pourrait devenir un vecteur d'injection, à examiner
5. Règle PSSI	**Écarts établis dans le scénario : 5.2**, compte personnel traitant les informations d'Hexalp ; **5.5**, secrets en clair dans le script. **2.3** si le traitement C2 n'est pas validé ; **4.4** si abonnement/service souscrit sans accord, modalités à vérifier. **8.1** : signaler la suspicion d'exposition. **7.1** seulement si données personnelles effectivement transférées, non démontré par les noms de colonnes
6. Qualification	**G4 × V3 = 12 — Critique**, pour l'accès non autorisé via secrets exposés dans le script et le traitement automatisé mal maîtrisé : impact C3 potentiel, mais lecteurs du fichier et exploitation inconnus. Pour la seule sortie récurrente de données C2 décrite par le script : **G3 × V4 = 12**, sous réserve de confirmer qu'il tourne ; le cron ne prouve pas chaque envoi
7. Mesure	Mettre en pause le résumé externe en conservant l'alerte Zabbix native ; renouveler les secrets, vérifier permissions de fichier et traces, puis migrer vers un projet API d'entreprise, secrets gérés, données minimisées, validation du service et journalisation sans contenu sensible. Procédure d'astreinte : les suggestions restent à vérifier avant action

Travail encore possible : oui. Les alertes Zabbix originales restent le canal de référence. Un résumé interne ou une intégration approuvée peut reprendre ensuite. Ne pas arrêter la supervision pour arrêter le résumé.

Preuves à obtenir : exécutions et erreurs du cron sur la période, configuration effective et droits du script, projet et clés API, consommations, contenu réellement transmis, droits/canal du webhook et validations. La variable du webhook n'est pas sa valeur : aucun jeton Teams n'est visible dans l'extrait, mais son stockage et sa révocation doivent être vérifiés.

U2 — Julien : diagnostic WMS avec configuration et logs sur un compte personnel

Source : P7. Besoin métier : rétablir le WMS lors d'un incident nocturne. **Statut : usage avéré dans la transcription du dossier**, sur compte personnel gratuit ; fournisseur OpenAI/ChatGPT fortement corroboré par P2 ; approbation non précisée. Nadia connaît au moins cet usage lorsqu'elle récupère la conversation avec l'accord de Julien ; sa connaissance préalable reste inconnue.

Étape	Analyse
1. Outil et fournisseur	Assistant public en P7 ; P2 associe j.martin à chatgpt.com avec un pic le 24/09. Le rapprochement soutient fortement ChatGPT, sans preuve technique reliant chaque requête à la conversation
2. Compte	Compte personnel gratuit de Julien, adresse **[ADRESSE PERSONNELLE CAVIARDÉE]**. Administration du compte et conservation dépendent du fournisseur, à identifier
3. Données	Configuration HAProxy : IP, noms des backends, ports et routage **C2** ; configuration de sécurité et mot de passe de l'interface stats **[CAVIARDÉ]**, **C3**. Le chemin du certificat est divulgué, **pas le contenu du certificat ni une clé privée**. Envoi annoncé de 2 400 lignes : données clients, personnelles ou autres secrets possibles mais non vérifiables sans l'extrait complet
4. Accès et connecteurs	Copier-coller, aucun connecteur démontré. L'assistant génère une commande de redémarrage/modification des contrôles de santé/rechargement ; il ne l'exécute pas lui-même. « Ça remarche » rapporte une amélioration, **pas la preuve d'exécution exacte ni d'une correction durable**
5. Règle PSSI	**5.2** : écart établi pour le compte personnel. **5.5** : secret transmis en clair dans le message, écart établi. **2.3** si le service n'est pas validé pour C2/C3, à confirmer. **7.1** si les logs contiennent des données personnelles transférées, contenu et contrat à vérifier. **8.1** : traiter le signalement et rechercher l'étendue de l'exposition ; aucune preuve d'un manquement au délai de signalement n'est fournie
6. Qualification	**G4 × V4 = 16 — Critique pour l'exposition décrite du secret C3**. Une utilisation malveillante de ce secret n'est pas prouvée. L'application non revue d'une commande en production constitue un scénario supplémentaire d'intégrité/disponibilité à vérifier, non une exécution démontrée
7. Mesure	Renouveler le secret stats, vérifier sa portée et les accès ; récupérer les preuves avec accès restreint. Contrôler l'état HAProxy/WMS et les changements réellement appliqués, puis tester et corriger avec retour arrière prévu. Fournir un circuit de dépannage avec extraits minimisés et outil approuvé, même pendant l'astreinte

Travail encore possible : oui. Diagnostic local à partir des outils d'exploitation et des logs internes ; consultation externe uniquement avec contenu autorisé et minimisé. Ne pas reproduire ni exécuter la commande du dossier : elle ne prouve pas que la cause des erreurs 502 a été traitée.

Preuves à obtenir : fournisseur, réglages et historique disponibles, contenu envoyé, chronologie de signalement, changements système et version de la configuration, tests de santé et accès à l'interface stats. La réponse du chatbot affirmant que les backends sont DOWN doit être vérifiée dans les traces réelles.

U3 — RH : noter et classer 340 candidatures dans TalentSort

Source : P8. Besoin métier : faciliter l'examen de nombreuses candidatures de caristes et éviter les imports manuels. **Statut : test déjà utilisé et déclaré au support le 23/09**, validation préalable inconnue. La demande d'intégration ne prouve pas une connexion existante au logiciel RH.

Étape	Analyse
1. Outil et fournisseur	TalentSort, outil fictif ; éditeur juridique, hébergement et sous-traitants inconnus. Essai gratuit de 30 jours : l'absence de paiement n'établit ni absence de contrat ni innocuité
2. Compte	Identité du titulaire, type de compte, administrateur et possibilité de clôture non fournis. Ne pas inventer un compte personnel
3. Données	**340 candidatures déjà importées selon le mail**, données personnelles **C2**, avec évaluations générées. Champs exacts et éventuelles données plus sensibles inconnus : ne pas les attribuer sans examen
4. Accès et connecteurs	Imports manuels et notation automatique déclarés. Connexion RH **demandée seulement**. Destinations, conservation, export et suppression des copies à vérifier. Aucun rejet automatique ni décision exclusivement automatisée de recrutement n'est démontré
5. Règle PSSI	**2.1, 2.3** : traitement C2, écart à 2.3 si service non validé. **7.1** : contrat prestataire validé DPO requis par la PSSI, preuve absente ; ce n'est pas à elle seule la preuve qu'aucun contrat n'existe. **4.4** : vérifier l'accord DSI sur l'essai si celui-ci constitue un abonnement. **5.2** seulement si compte personnel confirmé. **8.1** : saisir Nadia si l'import apparaît non autorisé
6. Qualification	**G3 × V4 = 12 — Critique pour la perte de maîtrise potentielle de données personnelles déjà confiées au service** : 340 candidatures déclarées transférées, garanties non documentées. Ce score ne prouve ni violation réglementaire ni fuite publique ; l'équité et la fiabilité des notes sont aussi à examiner
7. Mesure	Suspendre nouveaux imports et raccordement RH ; identifier contrat, accès, copies et suppression possible, avec DSI/DPO/RH. Reprendre la sélection humaine dans l'outil RH autorisé ; définir les critères, la revue des notes, la conservation et les conditions d'une éventuelle expérimentation validée

Travail encore possible : oui. L'équipe RH conserve son processus manuel dans le système autorisé ; elle ne doit pas considérer les notes TalentSort comme des décisions fiables sans validation. Pas de suspension générale du recrutement.

Preuves à obtenir : validation, conditions de l'essai, contrat et avis DPO, nature des documents importés, droits, historique d'accès et d'export, suppression et rôle réel des scores dans les décisions. Les conséquences réglementaires éventuelles demandent une analyse dédiée ; elles ne sont pas tranchées ici.

U4 — HelpFlow Assist : IA embarquée potentiellement active dans les tickets

Source : P9. Besoin métier : résumer les tickets et accélérer les réponses aux clients. **Statut : outil de support approuvé en 2023, nouvelle fonction IA annoncée active par défaut**. L'usage effectif de cette fonction reste à confirmer ; l'ancienne validation ne suffit pas à établir celle du nouveau traitement.

Étape	Analyse
1. Outil et fournisseur	HelpFlow et fonction HelpFlow Assist, sous-traitant IA annoncé aux États-Unis. Identité, chaîne contractuelle, version déployée et lieux réels de traitement/conservation inconnus
2. Compte	Espace de support existant ; administrateurs, paramétrage IA et personnes autorisées à modifier ces réglages à identifier. Aucun compte personnel montré
3. Données	Les tickets contiennent noms, adresses et téléphones de clients : **C2**. La note ne démontre pas qu'ils ont effectivement été envoyés au sous-traitant ni dans quel volume
4. Accès et connecteurs	Fonction intégrée pouvant exploiter les tickets et suggérer des réponses. Aucun envoi autonome de réponses n'est démontré ; aucun consentement OAuth distinct n'est fourni. Un flux serveur à serveur peut ne pas apparaître au proxy des postes
5. Règle PSSI	**2.1, 2.3, 7.1** : vérifier périmètre de validation et contrat DPO avant traitement personnel par le sous-traitant ; écart si traitement hors périmètre confirmé. **4.4** : contrat existant, avenant et conditions de la nouvelle fonction à vérifier. Aucune infraction ne découle automatiquement de la seule localisation américaine
6. Qualification	**G3 × V3 = 9 — Élevé, provisoire** pour un traitement externe non maîtrisé : impact personnel/client potentiel et activation par défaut annoncée, mais déploiement, invocation et garanties inconnus. Si un traitement régulier est confirmé hors cadre, réexaminer la cote, notamment V4 et le niveau 12
7. Mesure	Vérifier l'état et désactiver provisoirement la fonction IA si active tant que le périmètre n'est pas évalué ; conserver HelpFlow pour les tickets ordinaires. Examiner avec fournisseur, DSI et DPO les données traitées, garanties, sous-traitants, conditions de transfert, rétention et changement contractuel

Travail encore possible : oui. Le support peut continuer à traiter les tickets sans résumés IA. Une réactivation documentée est envisageable après validation ; aucune désactivation n'a été effectuée pour cette fiche.

Preuves à obtenir : version en production, paramètres, dates d'activation et d'appels, flux et journaux fournisseur, avenants et validation DPO. La note de version n'est ni une preuve d'installation ni une mesure de volume exfiltré.

U5 — ChatGPT côté commercial : S. Roux et L. Garnier

Sources : P2, P3. Besoin métier : à demander, sans inventer rédaction de mails ou contrats. **Statut : accès observés ; abonnement S. Roux documenté ; approbation DSI inconnue.**

Étape	Analyse
1. Outil et fournisseur	ChatGPT/OpenAI : s.roux, PC-COM-03, 388 requêtes, 4,2 Mo envoyés/31 Mo reçus ; l.garnier, PC-COM-05, 12 requêtes, 0,3 Mo/2,1 Mo
2. Compte	S. Roux : abonnement remboursé 23 €, validation Marc ; type exact et titulaire à vérifier. Compte L. Garnier inconnu. Ne pas déduire « personnel » du seul remboursement
3. Données	Contenu et classe PSSI inconnus ; les octets ne prouvent ni données clients ni secrets
4. Accès	Trafic web ; aucun connecteur ChatGPT établi. Les permissions MeetNote ne doivent pas être attribuées à ChatGPT
5. PSSI	**4.4** : remboursement par Marc ne prouve pas accord DSI ; écart si absence confirmée. **5.2** si compte personnel et informations Hexalp ; **2.3/7.1** selon données. Aucune de ces conditions ne se déduit du volume seul
6. Qualification	**G3 × V2 = 6 — Modéré, hypothèse de données commerciales C2** ; contenu et fréquence métier non établis. Si C0 seulement, baisse à examiner ; si secrets, hausse majeure. Ce score de travail ne constitue pas un constat de fuite
7. Mesure	Vérifier comptes, usages et validation ; fournir un espace approuvé, minimisation et formation. Recueillir un échantillon caviardé autorisé plutôt que réclamer tout l'historique personnel

Continuité : conserver les tâches métier par outils habituels ou assistant approuvé ; besoin précis et preuves à compléter avec les deux personnes. Deux utilisateurs ne deviennent pas deux familles d'outils supplémentaires.

U6 — MeetNote AI : trois consentements et un achat commercial

Sources : P3, P4. Besoin présumé : assistance aux réunions, à confirmer. Statut : souscription et consentements établis, traitements effectifs non détaillés.

Étape	Analyse
1. Outil et fournisseur	MeetNote AI, MeetNote Inc., éditeur vérifié. L'identité vérifiée ne garantit ni validation DSI ni sécurité du produit
2. Compte	Achat Pro 3 seats de 54 € le 12/09 sur carte Marc ; consentements m.delorme, s.roux, l.garnier le même jour. Contrat, propriétaires et rôles à vérifier
3. Données	Profil, réunions, messagerie, agenda et fichiers potentiellement accessibles ; **C2** proposé pour les contenus métier/personnels ; aucune collecte intégrale prouvée
4. Accès	User.Read, Calendars.ReadWrite, OnlineMeetings.Read, Mail.Read, Mail.Send, Files.Read.All, offline_access : lecture étendue, modification agenda, envoi de mails et renouvellement possible. Pas de transcription réalisée prouvée par OnlineMeetings.Read seul
5. PSSI	**4.4** si souscription sans accord DSI ; **2.3/7.1** selon traitements et garanties. Compte professionnel ne règle pas la validation. L'extrait PSSI encadre mal les consentements excessifs et leur revue
6. Qualification	**G4 × V3 = 12 — Critique**, estimation prudente pour détournement de capacités accordées : envoi au nom des utilisateurs, accès fichiers et renouvellement ; succès d'une injection et accès permanent effectif non démontrés
7. Mesure	Faire examiner et retirer les consentements excessifs, révoquer les jetons concernés et contrôler les accès ; ne conserver qu'un périmètre approuvé. Validation DSI du fournisseur et contrat DPO si applicable ; contrôle humain imposé pour toute action à impact

Continuité : notes de réunion manuelles ou solution validée, sans bloquer les échanges commerciaux. **Preuves :** contrats, paramètres, permissions effectives, journaux d'activité et conservation. Le manque de trace proxy ne contredit pas un traitement de serveur à serveur.

U7 — AI Summarizer Pro : extension sur 14 postes

Sources : P2, P5. Besoin présumé : résumé de pages, à confirmer avec les métiers. Statut : installation et trafic corroborés.

Étape	Analyse
1. Outil et fournisseur	Extension Chrome AI Summarizer Pro 2.4 ; domaine api.aisummarizer-pro.com ; éditeur juridique et garanties inconnus
2. Compte	Comptes, abonnement, administration et validation inconnus ; 14 postes des services commercial, ADV, RH et comptabilité
3. Données	21 400 requêtes, 96 Mo envoyés et 12 Mo reçus ; pages et historique potentiellement accessibles, mais contenu réel inconnu. Hypothèse C2 à vérifier compte tenu des métiers ; pas de preuve de tous les sites exfiltrés
4. Accès	Autorisation de lire/modifier les données de tous les sites et de lire l'historique ; modification possible de l'affichage/contenu des pages, sans preuve d'écriture générale dans les bases du SI
5. PSSI	**4.1** : vérifier catalogue et accord ; écart si non validée. **2.3/5.2/7.1** selon contenu, compte et transfert. Installation d'une extension = logiciel selon l'interprétation de 2.6
6. Qualification	**G3 × V3 = 9 — Élevé, provisoire**, pour exposition potentielle de données métier/personnelles par extension très active et très permissive ; si action critique possible ou C3 confirmé, recoter
7. Mesure	Suspendre l'extension sur le périmètre concerné dans l'attente de l'évaluation, examiner permissions et traces, puis limiter les sites et fournir un résumé approuvé. Inventaire central des extensions et circuit de validation

Continuité : consultation normale des applications et résumé manuel ou outil validé. **Preuves :** liste précise des postes/utilisateurs, politiques navigateur, données envoyées, fournisseur et contrat. 14 postes ne signifient pas nécessairement 14 personnes uniques.

U8 — GitHub Copilot : deux postes de développement

Sources : P2, P5. Besoin présumé : assistance au code, à confirmer. Statut : extension installée et trafic observé.

Étape	Analyse
1. Outil et fournisseur	GitHub Copilot dans VS Code : PC-DEV-01/t.nguyen, 2 950 requêtes, 18 Mo envoyés/41 Mo reçus ; PC-DEV-03/a.bernard, 1 870 requêtes, 11 Mo/26 Mo
2. Compte	Hexalp ne possède aucune licence Copilot selon P5. Cela ne prouve ni absence de licence individuelle ni absence d'accès gratuit/essai ; comptes, offre et garanties à vérifier
3. Données	Contexte de code potentiellement envoyé, **C2 si code source Hexalp** ; contenu exact et secrets éventuels inconnus
4. Accès	Extension IDE et API ; périmètre de contexte, agent, outils d'exécution et accès aux dépôts non fournis. Ne pas affirmer une exécution autonome
5. PSSI	**4.1**, catalogue/validation à vérifier ; **4.4** selon souscription ; **5.2** si compte personnel traitant du code Hexalp ; **2.3** si traitement C2 hors service validé ; **5.5** seulement si secrets effectivement présents
6. Qualification	**G3 × V3 = 9 — Élevé sous hypothèse de code interne**, vu l'activité sur deux postes et garanties non établies ; gravité à revoir selon dépôts et capacités réelles
7. Mesure	Vérifier offre, titulaires, réglages et contenu accessible ; déployer un périmètre administré validé, exclure secrets/dépôts sensibles et imposer revue/tests avant intégration. Suspendre les envois non évalués en gardant IDE et outils locaux autorisés

Continuité : développement et revue habituels maintenus. **Preuves :** validation des installations, comptes, contrat, configuration du contexte et journaux utiles sans collecte systématique du code.

U9 — Ollama sur PC-DEV-04 : installation à qualifier

Source : P5. Besoin supposé : expérimentation locale, non confirmé. Statut : installation constatée ; aucun usage de modèle démontré.

Étape	Analyse
1. Outil et fournisseur	Ollama, absent du catalogue DSI ; modèles téléchargés, versions et provenance inconnus
2. Compte	Utilisateur, administration du poste et éventuels comptes de services inconnus ; un fonctionnement sans compte reste possible
3. Données	Aucun prompt, fichier ou traitement identifié. Ne pas déduire que le code ou des secrets ont été ingérés
4. Accès	Interfaces exposées, réseau, droits et outils raccordés à vérifier. « Ollama installé » ne prouve ni hors ligne, ni modèle local actif, ni absence de télémétrie ou de services externes
5. PSSI	**4.1** : absence du catalogue établie, mais une validation exceptionnelle reste possible ; écart seulement si elle manque. **2.3/5.5** selon données et configuration, non démontrées
6. Qualification	**G2 × V2 = 4 — Modéré, scénario hypothétique d'expérimentation sur poste sans accès production** ; pas une mesure d'un usage observé. Si privilèges élevés ou exposition réseau, réévaluer
7. Mesure	Identifier propriétaire et validation, examiner modèles, ports et droits ; limiter le test à un environnement approuvé, sans données sensibles ni accès production. Formaliser les règles d'expérimentation

Continuité : développement classique maintenu ; environnement de test autorisé possible. **Preuves :** validation exceptionnelle, modèles présents et traitements, configuration réseau et propriétaire du poste.

U10 — DeepL sur le poste ADV

Source : P2. Besoin présumé : traduction, à confirmer. Statut : accès web observé, contenu traduit inconnu.

Étape	Analyse
1. Outil et fournisseur	www.deepl.com, PC-ADV-02/c.petit : 35 requêtes, 22 Mo envoyés et 24 Mo reçus
2. Compte	Compte, offre gratuite/payante, contrat et validation DSI non fournis ; ne pas attribuer une politique de données sans les identifier
3. Données	Textes ou fichiers possibles, sans preuve de traduction d'un contrat ni de données clients. **C2 retenu uniquement comme hypothèse de travail ADV**
4. Accès	Trafic web ; aucun connecteur ni accès à tous les documents de l'utilisateur établi
5. PSSI	**2.1/2.3** selon contenu ; **4.4** si abonnement ; **5.2** si compte personnel pour informations Hexalp ; **7.1** si données personnelles transférées. Faits insuffisants pour déclarer ces écarts établis
6. Qualification	**G3 × V2 = 6 — Modéré, conditionnel au traitement C2/personnel**, avec usage et garanties à confirmer ; le volume n'est pas une preuve de sensibilité
7. Mesure	Clarifier besoin, offre et données ; solution de traduction validée pour les classes autorisées, minimisation et procédure pour documents confidentiels

Continuité : traductions possibles par contenu public/minimisé dans le cadre approuvé ou traitement interne adapté.
Preuves : titulaire, validation, conditions et exemples caviardés consentis de documents concernés.

Actions prioritaires

Ordre proposé ; les premières actions peuvent être conduites en parallèle. Échéances relatives à la réception du dossier.

Priorité 1 — Immédiat

Ouvrir le suivi auprès de Nadia, préserver les preuves sous accès restreint, renouveler les secrets concernés de P6/P7, limiter leur accès et rechercher les usages anormaux ; vérifier les changements réels sur le WMS

Qui : Nadia pilote ; administrateurs WMS, base, API et supervision exécutent avec Sofia et Julien

Continuité et preuve : Maintenir WMS et alertes natives ; rotation coordonnée pour éviter une panne. Attendre confirmations de révocation, contrôles d'accès et tests de service, sans copier les secrets dans le rapport

Priorité 2 — Immédiat

Suspendre les nouveaux imports et l'intégration TalentSort ; établir le périmètre des 340 dossiers, les accès, les contrats et les possibilités de récupération/suppression ; faire évaluer les suites par DPO/RSSI

Qui : Responsable RH, DPO, Nadia et DSI

Continuité et preuve : Continuer le recrutement dans l'outil RH autorisé ; preuves d'arrêt des nouveaux flux, état des copies et décision documentée sur les données déjà confiées

Priorité 3 — Immédiat

Mettre en pause le résumé externe de Sofia sans couper Zabbix ; vérifier puis désactiver provisoirement HelpFlow Assist si actif. Traiter les permissions MeetNote établies en P4, suspendre AI Summarizer Pro le temps de son évaluation, et contrôler Copilot/Ollama sans confondre installation et usage

Qui : DSI, administrateurs supervision, HelpFlow et identité/M365

Continuité et preuve : Alertes Zabbix et support classique conservés ; preuves des réglages, de l'arrêt des flux concernés et inventaire des droits. Ne pas révoquer indistinctement toutes les applications du tenant

Priorité 4 — Sous 30 jours

Compléter l'inventaire en sept étapes avec les équipes, recouper proxy, achats, parc, consentements et sondage ; fournir des solutions approuvées pour dépannage, synthèse d'alertes, support et RH, avec comptes administrés et engagements vérifiés

Qui : DSI et Nadia avec managers, achats, DPO et métiers

Continuité et preuve : Inventaire consolidé avec identifiant unique, source, propriétaire, statut et preuve ; tests sur données fictives, validation du périmètre et procédure d'arrêt pour chaque solution

Priorité 5 — Dans le trimestre

Formaliser la politique IA et ses liens PSSI : changements des fonctions embarquées, droits/connecteurs, secrets et contexte automatique, contrôle humain, conservation, traçabilité, procédure de validation et dérogation suivie

Qui : Nadia propose ; DSI, DPO et métiers contribuent ; direction approuve selon les responsabilités d'Hexalp

Continuité et preuve : Politique approuvée, responsables et dates de revue ; formation avec exemples, suivi des demandes et vérification de l'adoption. Un texte publié seul n'est pas une preuve d'application

Mesures proposées, non exécutées. Réévaluer les risques résiduels après vérification des preuves.

Note de synthèse au RSSI

Objet : état des lieux des usages IA — dossier du 21 au 25 septembre 2026

Nadia,

Les dix pièces permettent de constituer dix fiches, couvrant neuf familles d'outils : API OpenAI, ChatGPT, TalentSort, HelpFlow, MeetNote, AI Summarizer Pro, Copilot, Ollama et DeepL. Le niveau de preuve varie : échanges ou imports décrits, trafic, achats, consentements, installations et fonction embarquée annoncée. HelpFlow reste à vérifier en production ; Ollama est installé sans usage établi. Côté commercial, le remboursement ChatGPT validé par Marc, l'achat de trois sièges MeetNote et les consentements contredisent l'absence générale d'outils IA déclarée, sans prouver une intention de dissimulation ni tous les contenus traités.

Les **trois risques prioritaires** sont **1)** les secrets en clair du script de Sofia et ceux transmis dans le dépannage WMS de Julien ; **2)** les données personnelles des 340 candidatures déjà importées et celles potentiellement traitées dans HelpFlow ; **3)** les accès étendus et traitements répétés, notamment MeetNote — fichiers, mails, envoi, agenda et renouvellement — et l'extension AI Summarizer présente sur 14 postes. Les changements WMS proposés par le chatbot doivent être vérifiés : le retour de Julien ne prouve pas l'exécution exacte ni la résolution durable.

La PSSI couvre déjà comptes personnels, secrets, validation des services et contrats DPO. Les écarts établis concernent notamment 5.2/5.5 pour les cas Sofia et Julien ; ailleurs, vérifier les autorisations avant de conclure. Ses angles morts concernent les nouvelles fonctions embarquées, les extensions et connecteurs, les accès prolongés, le contexte automatique, la conservation et la validation des actions générées. Le sondage de juin — 72 % ne sachant pas si l'usage est autorisé, 84 % favorables à un outil fourni — soutient le besoin d'un cadre lisible, sans mesurer l'activité de septembre.

Je propose de traiter immédiatement les secrets, arrêter les nouveaux imports RH et réduire les connexions ou flux non évalués, tout en maintenant WMS, alertes, support et recrutement. Sous 30 jours : compléter les preuves et fournir les solutions approuvées. Dans le trimestre : adopter une politique IA articulée à la PSSI et un circuit de réponse suivi aux besoins métier. Les volumes proxy ne révèlent pas le contenu envoyé ; aucun total fiable de salariés utilisateurs uniques n'est disponible.

Réponse au manager

Bonjour Marc,
Merci pour ton retour ; notre recensement inclut aussi les assistants de réunion et les fonctions intégrées.
Les pièces montrent un remboursement ChatGPT de S. Roux validé par toi et un achat MeetNote de trois sièges sur ta carte.
Elles montrent aussi des consentements MeetNote pour toi, S. Roux et L. Garnier, ainsi que du trafic ChatGPT sur deux postes commerciaux.
Ces éléments ne disent pas quels contenus ont été transmis ni comment les outils sont utilisés.
Peux-tu nous aider à préciser les besoins couverts, les comptes et les données concernés ?
Nous pourrons ainsi proposer des outils validés et limiter les accès inutiles sans bloquer le travail.
Le but est de sécuriser les pratiques et de donner des repères communs à l'équipe.
Merci pour ton aide, Nadia.

Statut

Brouillon destiné à Nadia ; aucun message envoyé. Les éléments cités proviennent de P2, P3 et P4. Ils ne démontrent ni les contenus transmis ni une volonté de dissimulation.

Vérifications restantes

Identifier les comptes, offres et validations DSI/DPO, contrôler les accès réellement utilisés, les copies et suppressions, et vérifier l'état de HelpFlow ainsi que l'usage d'Ollama. Ne pas extrapoler le sondage anonyme aux salariés non répondants.

Traçabilité du dossier

Pièce	Éléments disponibles	Croisement et limites
P1	Marc déclare le 22/09 que personne dans son équipe n'utilise l'IA	À rapprocher du remboursement ChatGPT validé par Marc, de l'achat MeetNote et des consentements ; ne démontre pas une intention de dissimulation
P2	Proxy du 21–25/09 : ChatGPT sur PC-COM-03, PC-COM-05, PC-INFRA-02 ; API OpenAI sur SRV-SUPERV-02 ; Copilot sur deux postes ; AI Summarizer sur 14 postes ; TalentSort ; DeepL	Corrobore plusieurs usages ; requêtes et octets ne sont ni des prompts ni des preuves de contenu. Le proxy ne couvre pas tous les flux serveur à serveur
P3	05/09 : abonnement ChatGPT de S. Roux, 23 €, validé par M. Delorme ; 12/09 : MeetNote AI Pro 3 seats, 54 €, carte M. Delorme ; achat SNCF 128,40 €	Dépenses IA établies, pas validation DSI. SNCF est exclu de l'inventaire IA, faute d'autre indice
P4	MeetNote AI, éditeur vérifié, consenti le 12/09 par m.delorme, s.roux et l.garnier : User.Read, Calendars.ReadWrite, OnlineMeetings.Read, Mail.Read, Mail.Send, Files.Read.All, offline_access	Établit les consentements, pas chaque lecture/envoi. Adobe Acrobat : User.Read, accord administrateur DSI le 03/02/2024 ; aucune fonction IA démontrée, donc hors inventaire IA
P5	AI Summarizer Pro 2.4 sur 14 postes ; GitHub Copilot sur PC-DEV-01/03, aucune licence détenue par Hexalp ; Ollama sur PC-DEV-04 hors catalogue	Installation et capacités de lecture/modification des pages et historique pour l'extension. Ne prouve pas tout le contenu transmis ni l'absence de licence individuelle Copilot
P6	Message Sofia du 17/09, cron toutes les cinq minutes, script API personnelle → Teams	Recoupé avec 1 440 requêtes et 52 Mo envoyés depuis SRV-SUPERV-02 en P2 ; aucun comptage des appels ne se déduit de la seule fréquence du cron
P7	Conversation WMS de Julien du 24/09, compte personnel gratuit, configuration et logs, proposition de commande	Recoupée avec j.martin sur PC-INFRA-02 : 96 requêtes, 3,9 Mo envoyés dont 3,6 Mo le 24/09. Le domaine ChatGPT devient fortement corroboré ; le contenu exact des 2 400 lignes reste absent
P8	RH : import déclaré de 340 candidatures, notation et demande de connexion future	Recoupé avec i.lefevre sur app.talentsort.io : 210 requêtes, 64 Mo envoyés. Ces octets ne prouvent pas la taille exacte des CV ni les 340 imports individuellement
P9	HelpFlow approuvé en 2023 ; nouvelle IA active par défaut annoncée, sous-traitant aux États-Unis	Version réellement déployée, activation et traitement effectif restent à confirmer ; absence de domaine dédié dans P2 non probante

Pièce	Éléments disponibles	Croisement et limites
P10	Sondage anonyme de juin : 212 répondants ; 61 % usage professionnel hebdomadaire ; parmi les utilisateurs : 38 % compte personnel, 9 % professionnel, 53 % inconnu/sans compte ; 72 % ne savent pas si autorisé ; 84 % prêts à utiliser un outil fourni	Indicateur collectif de besoin et de manque de repères ; pas d'attribution individuelle, de mesure de septembre ou de projection automatique aux 300 salariés

Bilan : dix fiches, correspondant à neuf familles d'outils. U1 et U2 restent distincts malgré le fournisseur commun OpenAI : résumé automatisé et dépannage manuel ont comptes, données et droits différents. U5 regroupe deux personnes utilisant ChatGPT côté commercial ; U8 regroupe les deux postes Copilot. U4 est un traitement potentiel et U9 une installation dont l'usage n'est pas prouvé : les dix fiches ne signifient pas dix usages actifs démontrés.

Ressources

- Méthode en sept étapes, PSSI fournie et grille de qualification. - ANSSI — Recommandations de sécurité pour un système d'IA générative. - OWASP — Top 10 LLM : repères complémentaires, notamment divulgation d'informations sensibles, traitement des sorties et capacités excessives.

Ressources externes consultées le **20 octobre 2026**. Les constats reposent sur les pièces fictives fournies ; les ressources ne prouvent pas l'activité d'Hexalp. Les actions, validations et acceptations de risque restent proposées.